TECHNICAL DETAIL

Title	Stored Cross-Site Scripting (XSS) via Malicious SVG File Upload
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://bertani.my.id/berbagi-berkas
Severity	**Medium**
CVSS Score	**5.4** **CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N**
Proof of Concepts	Please see Steps to Reproduce section

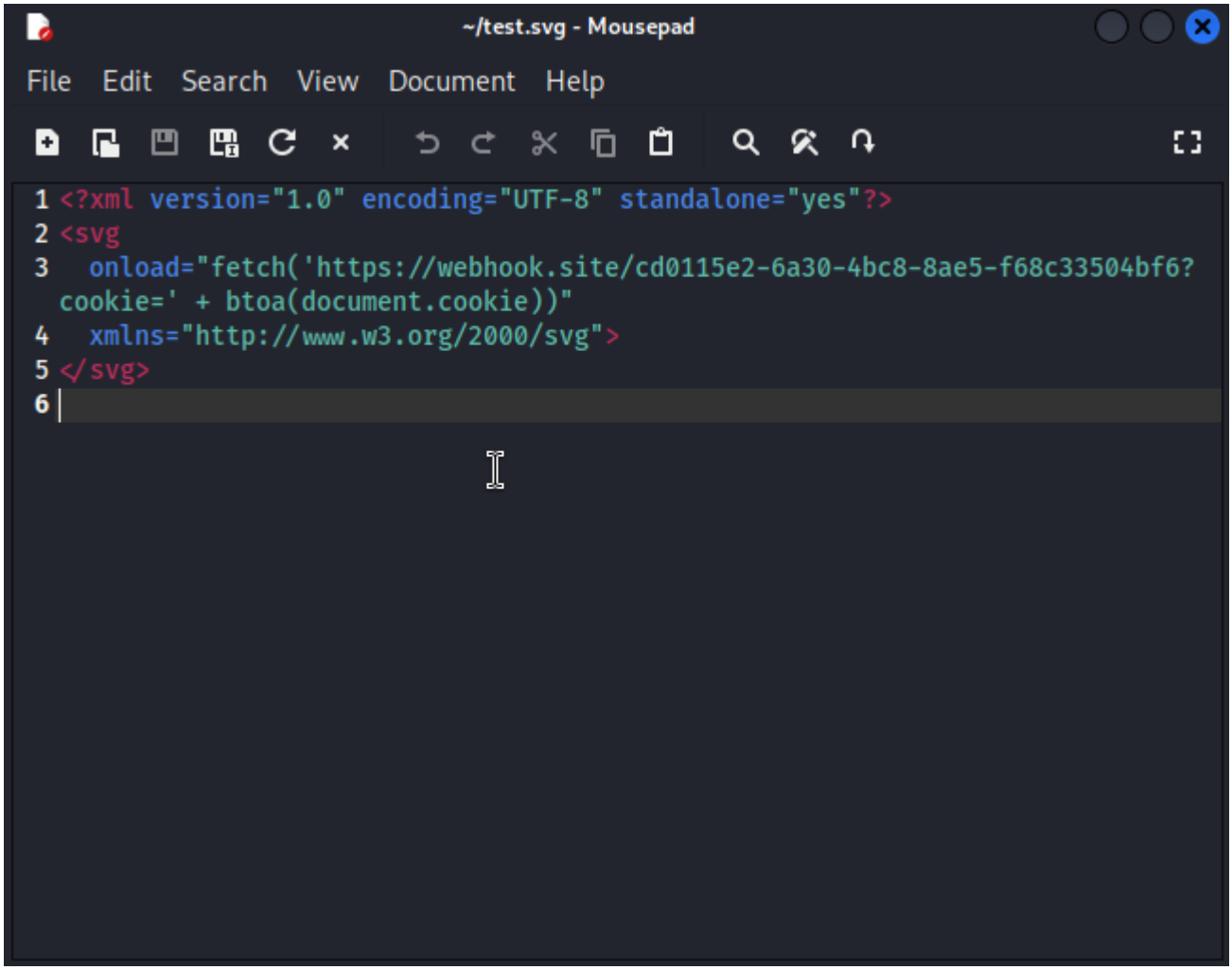
SUMMARY

Ditemukan kerentanan **Stored Cross-Site Scripting (XSS)** pada fitur unggah berkas di platform Bertani. Aplikasi memungkinkan pengguna untuk mengunggah file dalam format SVG tanpa validasi konten yang ketat. Penyerang dapat menyisipkan kode JavaScript berbahaya ke dalam file SVG tersebut yang akan dieksekusi oleh browser korban saat file diakses, sehingga memungkinkan pencurian *session cookies* secara otomatis.

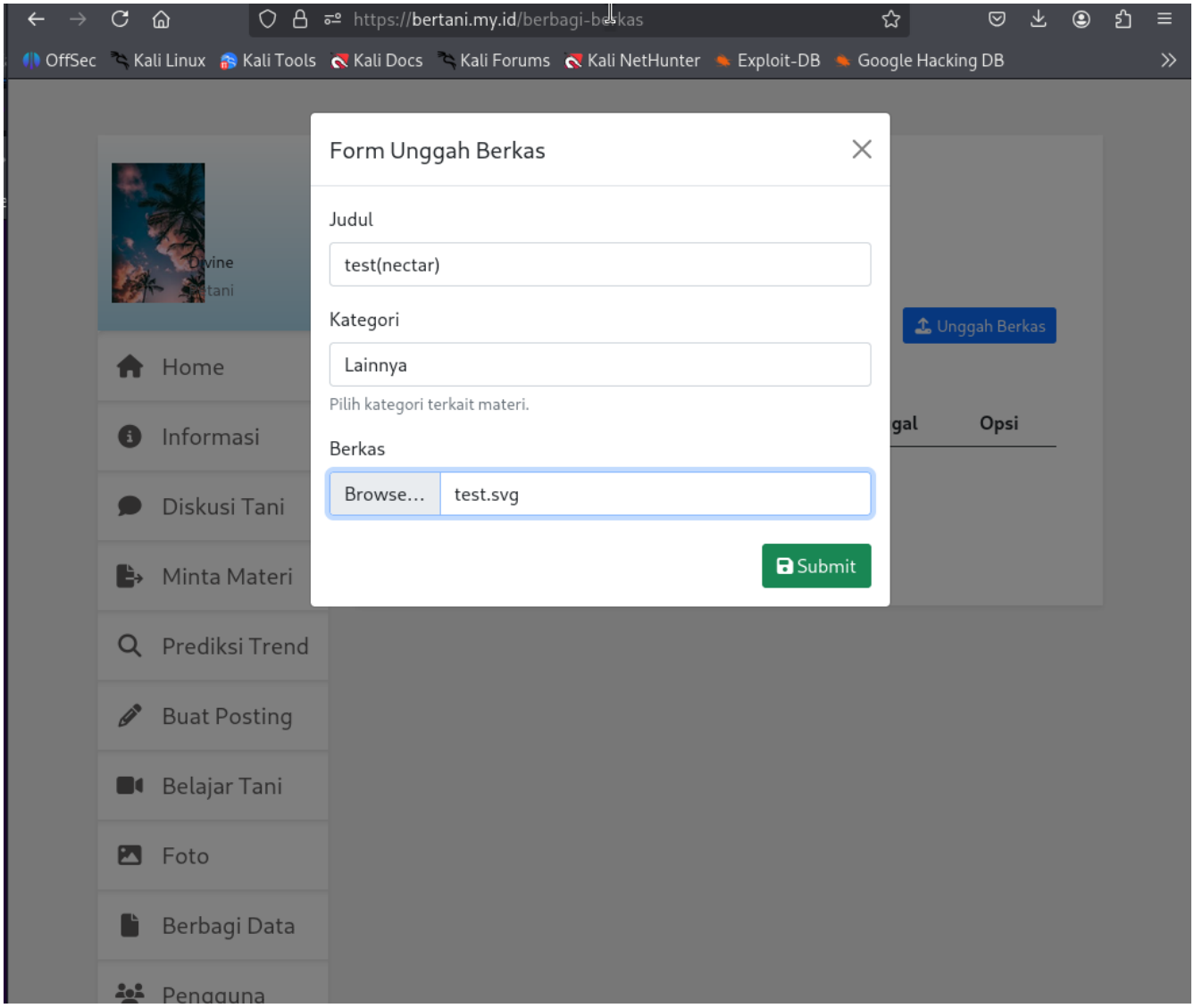
STEPS TO REPRODUCE

1. Login ke Akun Anda sebagai user ke URL https://bertani.my.id/login
2. Masuk ke URL https://webhook.site lalu copy unique URL nya

3. Buat file svg dan masukan unique URL kedalam kode berikut:

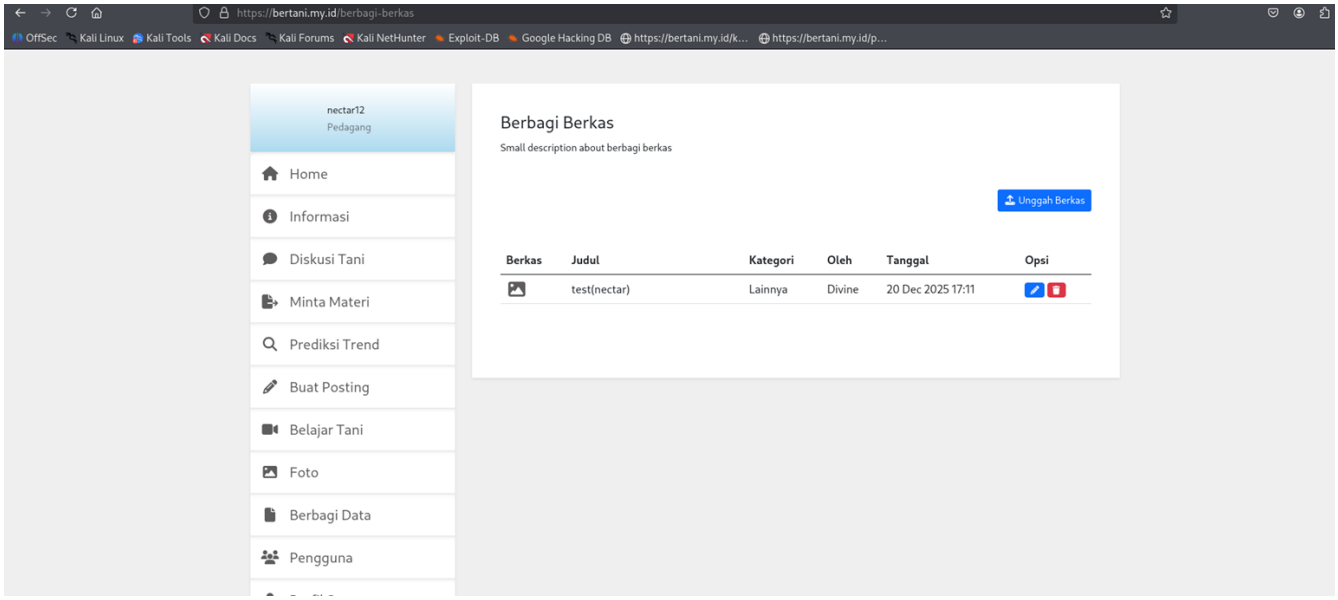


4. Buka url https://bertani.my.id/berbagi-berkas lalu isi berkas dengan file .svg yang telah dibuat



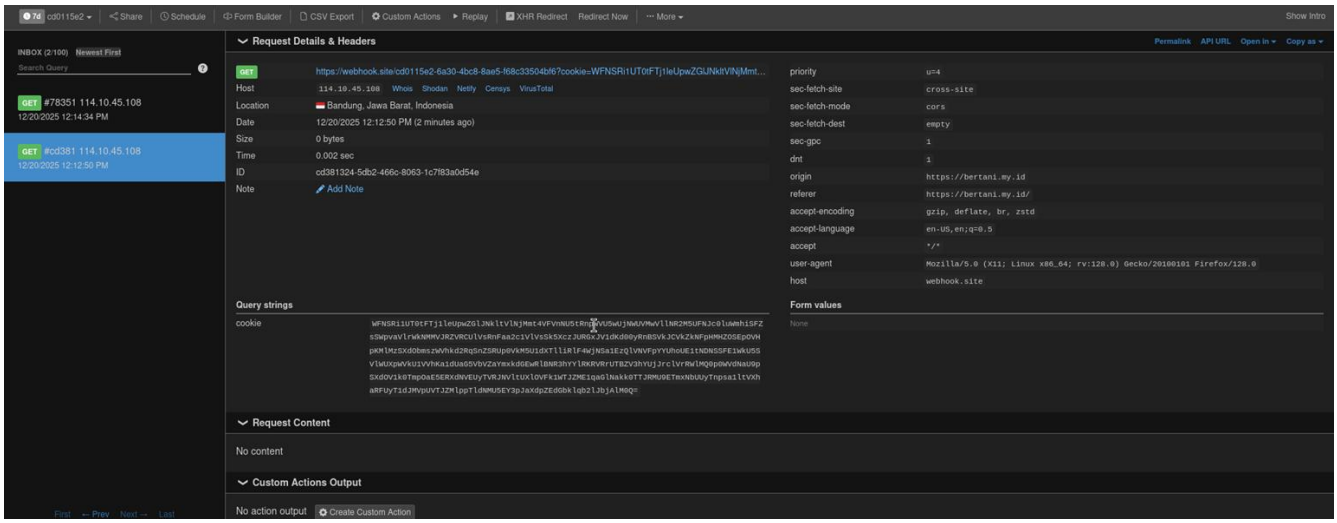
5. Login dengan Akun dummy anda di URL https://bertani.my.id/login

6. Buka url https://bertani.my.id/berbagi-berkas lalu tekan ikon gambar di kolom berkas



7. Tampilan saat user menekan ikon gambar

8. Buka Kembali webhooknya dan cookie korban berhasil didapat



EXPECTED RESULT

Sistem seharusnya melakukan proses sanitasi dan pembersihan secara menyeluruh terhadap setiap file SVG yang diunggah oleh pengguna. Hal ini bertujuan untuk mendeteksi dan menghapus tag skrip berbahaya atau atribut *event handler* seperti onload. Dengan penerapan validasi tersebut, *payload* XSS tidak akan tersimpan secara permanen di server, sehingga keamanan pengguna lain tetap terjaga dan risiko eksekusi skrip berbahaya pada sisi klien dapat dicegah sepenuhnya

ACTUAL RESULT

Aplikasi menerima dan menyimpan file SVG berbahaya tanpa adanya validasi konten yang ketat. Hal ini menyebabkan browser mengeksekusi kode JavaScript di dalam file SVG tersebut saat dibuka langsung melalui URL /storage/files/test.svg. Akibatnya, penyerang berhasil mendapatkan *cookie* korban yang dikirimkan secara otomatis melalui layanan Webhook.

IMPACT

Pencurian Sesi (Session Hijacking): Potensi pengambilalihan akun jika cookie tidak diamankan dengan benar dan File SVG bisa dimodifikasi untuk mengarahkan pengguna secara paksa ke situs berbahaya.

RECOMMENDATION

1. Gunakan library sanitasi SVG (seperti DOMPurify) untuk menghapus elemen berbahaya sebelum disimpan.
2. Terapkan Content Security Policy (CSP) yang ketat untuk membatasi sumber eksekusi skrip.
3. Tambahkan flag HttpOnly pada semua cookie sesi untuk memitigasi dampak pencurian data via XSS.

REFERENCES

1. **OWASP - Unrestricted File Upload:** https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload
2. **PortSwigger - SVG File Upload XSS:** https://portswigger.net/web-security/file-upload#uploading-files-using-other-techniques
3. **CWE-434: Unrestricted Upload of File with Dangerous Type:** https://cwe.mitre.org/data/definitions/434.html